FIDO-A3：同一オリジン制約を維持したWebAuthn認証証跡のRP外独立検証

五味 秀仁[1,a)]　大神 渉[1,b)]

概要：WebAuthn は公開鍵暗号に基づく認証方式として広く利用されているが，同一オリジン制約（Same-Origin Policy）により，認証証跡は認証を実施した Relying Party（RP）のみが検証可能であり，フェデレーション環境の Service Provider（SP）は Identity Provider（IdP）の認証結果を受け入れるほかない．本稿では，同一オリジン制約を維持したまま，RP 外の Verifier がハードウェアに裏付けられた WebAuthn 認証証跡を独立に検証可能とするフェデレーションアーキテクチャ FIDO-A3 を提案する．提案方式は，発行時鍵ローテーション（Rotation-on-Issuance）により継続的な認証とサービス間非リンク性を両立し，既存の WebAuthn 認証器，標準 Web ブラウザおよび OIDC/SAML 基盤上で追加ソフトウェアを必要とせず実現できる．試作実装および性能評価により，提案方式の実現可能性と実用性を示す．

キーワード：WebAuthn, フェデレーション認証, 信頼境界, 認証証跡, 独立検証

FIDO-A3: A Federation Architecture for Independent Verification of WebAuthn Authentication Evidence

Hidehito Gomi[1,a)]　Wataru Oogami[1,b)]

Abstract: WebAuthn is widely deployed as a public-key-based authentication mechanism. However, because its authentication evidence is bound by the same-origin security model, it can be verified only by the Relying Party (RP) that conducted the authentication, while a Service Provider (SP) in a federated environment must rely on the authentication result asserted by the Identity Provider (IdP). This paper proposes FIDO-A3, a federation architecture that enables a verifier outside the original RP to independently validate hardware-backed WebAuthn authentication evidence while preserving the same-origin security model. FIDO-A3 employs Rotation-on-Issuance to support continuous authentication while preventing cross-service linkability. It can be implemented using existing WebAuthn authenticators, standard web browsers, and OIDC/SAML infrastructures without requiring additional client software. A prototype implementation and performance evaluation demonstrate the feasibility and practicality of the proposed architecture.

Keywords: WebAuthn, Federated Authentication, Trust Boundary, Authentication Evidence, Independent Verification

1. はじめに

WebAuthn [1] は，公開鍵暗号方式とハードウェア認証器を利用したフィッシング耐性の高い認証方式として広く普及している．しかし，WebAuthn の認証証跡（Authentication Evidence）は，同一オリジン制約（Same-Origin Policy）に基づき，認証を実施した Relying Party（RP）のみが検証できるよう設計されている．このため，OpenID Connect（OIDC）[2] や Security Assertion Markup Language（SAML）[3] などのフェデレーション認証では，Service Provider（SP）は Identity Provider（IdP）が返す認証結果を受け入れることはできるものの，元の WebAuthn 認

[1] LINE ヤフー株式会社
LY Corporation
[a)] hgomi@lycorp.co.jp
[b)] wogami@lycorp.co.jp

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

証証跡そのものを独立に検証することはできない．

この制約は，認証責任を IdP に委ねるフェデレーション認証の設計思想と整合している一方，SP がハードウェアに裏付けられた認証の真正性や鮮度を自ら検証したい場合には制約となる．例えば，高い保証レベルを要求するサービスや，将来的な AI Agents への権限委譲などでは，認証結果だけでなく，その認証証跡自体を第三者が独立に検証可能であることが望ましい場面が考えられる．

一見すると，WebAuthn 認証証跡と対応する公開鍵を SP へ渡せばこの課題は解決できるように見える．しかし，そのまま認証鍵を共有すると，WebAuthn が前提とする同一オリジン制約を破壊するとともに，永続的な公開鍵がサービス横断で利用されることにより，ユーザ追跡やプライバシー侵害を招くおそれがある．したがって，認証証跡を RP 外へ運搬しながらも，同一オリジン制約とサービス間非リンク性を同時に維持することが必要となる．

本稿では，この課題を解決するフェデレーションアーキテクチャ FIDO-A3 を提案する．FIDO-A3 は，各 SP が独立に WebAuthn 認証基盤を構築することを目的とするものではなく，既存のフェデレーション運用を維持したまま，Authentication Evidence の検証範囲を RP 外へ拡張するアーキテクチャである．FIDO-A3 は，WebAuthn の同一オリジン制約を維持したまま，RP 外の Verifier がハードウェアに裏付けられた WebAuthn 認証証跡を独立に検証可能とする．そのために，認証鍵を発行時にローテーションする Rotation-on-Issuance（RoI）を導入し，継続的な WebAuthn 認証を維持しつつ，一回限りの検証用認証証跡を生成する．これにより，既存の WebAuthn 認証器，標準 Web ブラウザ，および OIDC/SAML 基盤を変更することなく，追加ソフトウェアを必要としない実装を実現する．

本稿の貢献は以下の 3 点である．第 1 に，WebAuthn の同一オリジン制約を維持したまま，RP 外の Verifier による認証証跡の独立検証を可能とするフェデレーションアーキテクチャ FIDO-A3 を提案する．第 2 に，発行時鍵ローテーション（RoI）により，継続的な認証とサービス間非リンク性を両立する設計を示す．第 3 に，FIDO-A3 の試作実装および性能評価を通じて，既存の WebAuthn 認証器，標準 Web ブラウザ，および OIDC/SAML 基盤上で追加ソフトウェアを必要とせず実現可能であることを示す．

2. 設計目標

本研究では，WebAuthn の認証証跡を RP 外の Verifier が独立に検証可能とするフェデレーションアーキテクチャを目指す．しかし，単純に WebAuthn 認証証跡と対応する公開鍵を RP から Verifier へ共有すると，同一オリジン制約を破壊するとともに，永続的な公開鍵を介したサービス横断のユーザ追跡を可能とする．したがって，本研究では，WebAuthn のセキュリティモデルを維持しながら認証証跡を運搬するため，以下の設計目標を設定する．

G1．RP 外 Verifier による独立検証
Verifier は，IdP が返す認証結果のみを信頼するのではなく，元の WebAuthn 認証証跡を用いて，ハードウェアに裏付けられた認証イベントを独立に検証できること．

G2．同一オリジン制約の維持
WebAuthn が提供する認証鍵のオリジン束縛を維持し，RP 外 Verifier による検証を実現するために，同一オリジン制約を破壊する設計を採用しないこと．

G3．サービス間非リンク性
認証証跡を RP 外へ運搬する場合であっても，永続的な識別子や公開鍵によって異なる Verifier 間で利用者が追跡されないこと．

G4．既存環境への適用容易性
既存の WebAuthn 認証器，標準 Web ブラウザ，および OIDC/SAML フェデレーション基盤を変更せず，追加ソフトウェアを利用者端末へ導入することなく適用可能であること．

本稿では，これら 4 つの設計目標を満たすフェデレーションアーキテクチャとして FIDO-A3 を提案する．次章では，そのシステム構成と基本設計について説明する．

3. FIDO-A3 アーキテクチャ

本章では，前章で示した設計目標を実現する FIDO-A3 アーキテクチャについて説明する．FIDO-A3 の基本的な考え方は，WebAuthn が提供するハードウェアに裏付けられた認証証跡を，同一オリジン制約を維持したまま RP 外の Verifier へ運搬し，Verifier 自身が独立に検証可能とすることである．

FIDO-A3 では，WebAuthn の認証鍵そのものを複数サービスで共有するのではなく，認証時に生成される認証証跡と検証用鍵を一回限り利用可能な形で Verifier へ提示する．その一方で，利用者は次回以降も通常どおり WebAuthn 認証を継続できるよう，新たな認証鍵を同時に登録する．

この設計により，

- WebAuthn の同一オリジン制約を維持すること，
- RP 外 Verifier による独立検証，
- 継続的な認証，
- サービス間非リンク性

を同時に実現する．

3.1 システム概要

FIDO-A3 は，利用者（User），WebAuthn 認証器（Authenticator），Identity Provider（IdP），および Service Provider（SP）から構成される．本稿では，IdP が WebAuthn 認証を実施する主体であり，同時に WebAuthn における Relying Party（RP）として動作するものとする．一方，SP は認証

© 2026 Information Processing Society of Japan

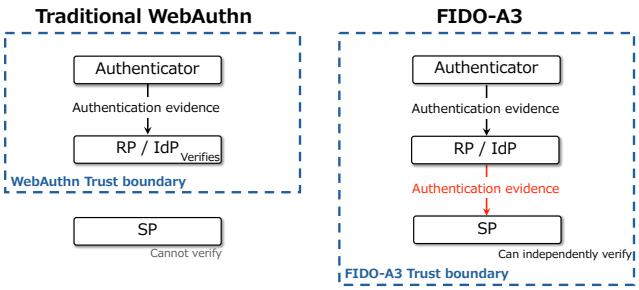


図 1 従来の WebAuthn と FIDO-A3 における認証証跡の検証範囲の比較．従来方式では Authentication Evidence は RP 内部に限定されるのに対し，FIDO-A3 では同一オリジン制約を維持したまま SP まで運搬され，SP による独立検証が可能となる．

Fig. 1 Comparison of the verification scope of authentication evidence in conventional WebAuthn and FIDO-A3. Conventional WebAuthn confines authentication evidence to the original RP, whereas FIDO-A3 transports authentication evidence to the SP while preserving the same-origin security model, enabling independent verification by the SP.

結果を利用する主体であり，従来方式では IdP から提示される認証結果のみを受け入れるが，FIDO-A3 では提示された WebAuthn 認証証跡を独立に検証する．

3.2 信頼境界の拡張

従来の WebAuthn では，認証証跡（Authentication Evidence）は認証を実施した RP のみが検証可能であり，認証証跡の検証範囲は WebAuthn の同一オリジン制約により RP 内部に限定される．そのため，フェデレーション環境における SP は，IdP が返す認証結果を利用できるものの，元の WebAuthn 認証証跡そのものを独立に検証することはできない．

図 1 に，従来方式と FIDO-A3 における認証証跡の検証範囲を示す．従来方式では，Authentication Evidence は RP までしか運搬されず，SP はこれを検証できない．一方，FIDO-A3 では，同一オリジン制約を維持したまま Authentication Evidence を SP まで運搬することにより，SP 自身がハードウェアに裏付けられた認証証跡を独立に検証できる．このように，FIDO-A3 は Authentication Evidence の検証範囲を RP 外へ拡張し，WebAuthn の Trust Boundary を SP まで拡張する．

ただし，この拡張を同一の WebAuthn Credential の継続的な共有によって実現すると，Credential に対応する公開鍵がサービス横断の永続的な識別子となり得る．FIDO-A3 では，この問題を回避するため，RoI を導入する．

3.3 Rotation-on-Issuance

WebAuthn Credential の公開鍵自体は秘密情報ではないが，Credential は登録先 RP に束縛され，その RP における継続的な認証のための識別子として管理される．したがって，同一 Credential の公開鍵を RP 外の複数 SP へ継続的に提示すると，本来 RP 内に閉じていた永続的な識別子をサービス間で共有することになり，異なる SP による利用者の関連付けを可能にし得る．一方，SP 向けに別の鍵を IdP が生成するだけでは，その鍵と Authenticator が生成した元の Authentication Evidence との暗号学的な対応関係を SP が確認できない．

FIDO-A3 では，この 2 つの要件を両立するため，RoI を導入する．RoI では，WebAuthn 認証に使用した Credential を，A3 発行時点で以後の RP 認証には使用しない 1 回限りの検証用 Credential へ移行させる．この Credential に対応する公開鍵と Authentication Evidence は発行される A3 へ格納され，SP による過去の認証イベントの独立検証にのみ利用される．

同時に，Authenticator は標準 WebAuthn Registration を用いて新しい Credential を生成し，RP はこれを次回以降の認証用 Credential として登録する．すなわち，RoI では，現在の Authentication Evidence を検証するための旧 Credential と，将来の WebAuthn 認証に用いる新 Credential の役割を A3 発行時に分離する．この旧 Credential の退役と新 Credential の登録は一つの状態遷移としてアトミックに実行し，A3 発行後も旧 Credential が将来の認証に有効なまま残る中間状態を生じさせない．

これにより，SP は Authenticator が生成した Authentication Evidence を旧公開鍵により独立に検証できる一方，同じ公開鍵が将来の認証や別の A3 発行で継続的に使用されることはない．また，新 Credential は従来どおり元の RP に束縛されるため，FIDO-A3 は WebAuthn の同一オリジン制約を解除したり，同一 Credential を複数サービス間で共有したりすることなく，Authentication Evidence の検証範囲のみを RP 外へ拡張する．

RoI は，単なる鍵更新ではなく，Credential の役割を認証から検証へ移行させる Credential Lifecycle 管理機構である．

RoI の基本的な状態遷移を付録 A.1 に示す．

3.4 プロトコル概要

図 2 に FIDO-A3 のプロトコル概要を示す．FIDO-A3 は，Authentication Layer における Registration および Authentication と，Federation Layer における RoI，A3 発行，Presentation の各フェーズから構成される．

Authentication Layer では，既存の WebAuthn を変更することなく，認証器と RP の間で登録および認証を実施し，RP は Registration Evidence および Authentication Evidence を検証する．

Federation Layer では，直前に検証された Authentication Evidence を起点として RoI を実行する．RP は標準

© 2026 Information Processing Society of Japan

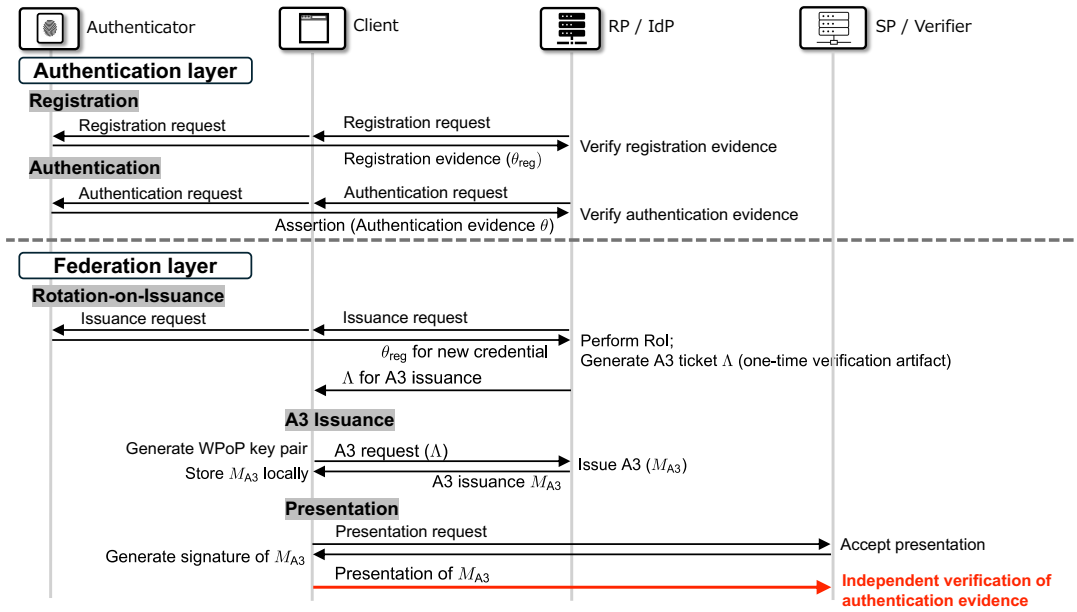


図 2 FIDO-A3 プロトコル概要．プロトコルは Authentication Layer における Registration および Authentication と，Federation Layer における RoI，A3 発行，Presentation の各フェーズから構成される．RoI により一回限りの A3 Ticket を生成し，SP は提示された Authentication Evidence を独立に検証できる．

Fig. 2 Protocol overview of FIDO-A3. The protocol consists of Registration and Authentication in the Authentication Layer, followed by RoI, A3 issuance, and Presentation in the Federation Layer. RoI generates a one-time A3 ticket, enabling the SP to independently verify the presented authentication evidence.

WebAuthn Registration によって新 Credential を登録し，認証に使用した旧 Credential を検証専用へ移行した後，この発行コンテキストに対応する一回限りの A3 Ticket を Client へ返す．

続く A3 発行では，Client が Presentation に用いる WPoP（Wallet-bound Presentation Proof）鍵ペアを生成し，A3 Ticket と WPoP 公開鍵を RP/IdP へ提示する．RP/IdP は，Authentication Evidence，その検証用公開鍵，WPoP 公開鍵，発行コンテキストを A3 へ結合して署名する．

Presentation では，Client は A3 と WPoP を SP へ提示する．SP はフェデレーションアサーションの署名，内部の Authentication Evidence，および Presentation 時の WPoP を検証することで，元の RP へ再照会することなく，ハードウェアに裏付けられた認証証跡を独立に検証する．

RoI の基本的な状態遷移，A3 の論理データ構造，および各フェーズの補足説明を付録 A.1〜A.3 に示す．

4. 安全性分析

本章では，第 2 章で示した設計目標が，第 3 章の FIDO-A3 アーキテクチャによってどのように実現されるかを分析する．本稿では，WebAuthn 認証器およびその暗号プリミティブが正しく動作し，署名の偽造やハッシュ値の衝突が困難であることを仮定する．また，ネットワーク上の攻撃者はメッセージの盗聴，改変，再送を試みることができるものとする．

FIDO-A3 が削減するのは，フェデレーション環境において SP が IdP による認証イベントの主張のみを受け入れなければならないという信頼である．一方，IdP が利用者属性やアカウント状態を正しく管理すること，および Authenticator が正規の WebAuthn 処理を実行することへの信頼は残る．以下では，認証証跡の真正性，RP 外での独立検証，サービス間非リンク性，および残存する信頼について順に述べる．

4.1 認証証跡の真正性

WebAuthn の Authentication Evidence は，Authenticator が生成した署名と，認証要求に対応するコンテキストから構成される．RP は，登録済み Credential に対応する公開鍵を用いて署名を検証するとともに，認証要求との対応関係，RP 識別子，および認証状態を確認する．したがって，攻撃者が Authenticator の秘密鍵を保持しない限り，正当な Authentication Evidence を新たに生成することは困難である．

FIDO-A3 では，この Authentication Evidence を IdP が生成した上位の認証結果へ置き換えるのではなく，A3 に含めて RP 外の SP まで運搬する．SP は A3 に対する IdP の署名だけでなく，A3 に含まれる元の Authentication Evidence とその検証用公開鍵を用いて，Authenticator が生

© 2026 Information Processing Society of Japan

成した署名を自ら検証する．このため，SP は IdP が単に「WebAuthn 認証を実施した」と主張したことだけでなく，対応する暗号学的証跡が存在することを確認できる．

4.2 RP 外 SP による独立検証

従来の WebAuthn では，Credential は登録先の RP に束縛されており，対応する Authentication Evidence の検証範囲も元の RP に限定される．FIDO-A3 は，この Credential を複数の SP で継続的に共有するのではなく，RoI によって認証済み Credential を一回限りの検証用 Credential へ移行させる．同時に，次回以降の WebAuthn 認証に用いる新しい Credential を RP へ登録するため，利用者は以後も通常の WebAuthn 認証を継続できる．

SP へ提示される A3 は，退役した検証用 Credential に対応する Authentication Evidence，検証用公開鍵，および IdP による発行情報を含む．SP はこれらを用いて Authentication Evidence を直接検証するため，元の WebAuthn 認証イベントの真正性について IdP の主張だけに依存しない．一方，新たに登録された Credential は引き続き元の RP に束縛されるため，FIDO-A3 は WebAuthn の同一オリジン制約を解除したり，同一の認証鍵を複数のサービスで共有したりするものではない．

4.3 サービス間非リンク性と一回限りの提示

単一の WebAuthn Credential または公開鍵を複数の SP へ提示すると，それらが永続的な識別子として機能し，異なる SP 間で利用者を関連付ける手掛かりとなり得る．FIDO-A3 では，RoI によって各発行時に従来の Credential を退役させ，対応する検証用 Credential および A3 を一回限りの提示に用いる．次回の認証では新たに登録された別の Credential が用いられるため，同一の公開鍵や Credential 識別子が複数の SP へ継続的に提示されない．

さらに，Client は A3 発行時に WPoP 鍵ペアを生成し，その公開鍵を A3 へ結び付ける．Presentation 時には，SP が提示した要求に対して WPoP 秘密鍵による署名を生成し，A3 とともに提示する．これにより，A3 を取得した第三者が，対応する WPoP 秘密鍵を保持せずに別の SP や別セッションで再提示することを防ぐ．SP は A3 および WPoP 署名を一回限り受理することにより，同一の A3 の再利用を拒否する．

以上より，FIDO-A3 のサービス間非リンク性は，単に Credential 識別子を置き換えることだけに依存するのではなく，Credential の退役，新 Credential の登録，1 回限りの A3 発行，および WPoP による提示拘束を組み合わせて実現される．

4.4 残存する信頼と適用範囲

FIDO-A3 は，フェデレーションにおけるすべての信頼を除去するものではない．SP は Authentication Evidence を独立に検証できる一方，利用者属性，アカウント状態，認証時刻，および IdP が付与するフェデレーション上の意味付けについては，引き続き IdP を信頼する必要がある．また，IdP が RoI を正しく実行し，退役した Credential を以後の認証に使用しないことも必要である．

A3 は一回限りかつ短期間の利用を前提とするため，長期利用される Verifiable Credential と同様の失効機構を必須とはしない．一方，Authenticator の紛失，利用者アカウントの停止，または IdP 自体の侵害に対しては，既存のアカウント失効，Credential 削除，および認証器管理の仕組みが必要となる．したがって，FIDO-A3 が提供する保証は，元の WebAuthn 認証イベントの真正性を RP 外の SP が検証可能にすることであり，IdP が提供するすべての属性や認可判断の正しさを保証するものではない．

以上の分析より，FIDO-A3 は，WebAuthn の同一オリジン制約を維持しながら，Authentication Evidence の検証範囲を RP 外の SP まで拡張する．また，RoI と WPoP を組み合わせることで，継続的な WebAuthn 認証，1 回限りの提示，およびサービス間非リンク性を両立する．次章では，これらの設計を実装し，既存環境上での実現可能性と追加コストを評価する．

5. 実装と評価

本章では，FIDO-A3 の試作実装を示し，既存の WebAuthn 認証器，標準 Web ブラウザ，およびフェデレーション基盤上で実現可能であることを確認する．さらに，FIDO-A3 によって追加される発行・提示・検証処理の実行時間とメッセージサイズを測定し，その実用性を評価する．

本評価の目的は，ネットワーク遅延や利用者操作時間を含む特定の配備環境における end-to-end latency を測定することではなく，FIDO-A3 が既存の WebAuthn およびフェデレーション処理へ追加する暗号処理，構文解析，およびメッセージ処理の増分コストを明らかにすることである．

5.1 試作実装

FIDO-A3 の実現可能性を検証するため，WebAuthn 認証器，Client，RP/IdP，および SP から構成される試作システムを実装した．バックエンドは Java 21.0.7 および Spring Boot 3.4.2 を用いて実装し，WebAuthn の登録・認証状態，RoI に用いる一時状態，ならびに A3 の発行・検証処理を統合的に管理する．ビルドには Gradle を使用した．

Federation Layer には SAML 2.0 および OIDC 1.0 の 2 つのプロファイルを実装した．SAML プロファイルには OpenSAML 4.3.0 を，OIDC プロファイルには Nimbus OAuth 2.0 SDK with OIDC Extensions 11.30.1 を使用し，それぞれ XML ベースの SAML Assertion および

© 2026 Information Processing Society of Japan

JSON/JWT ベースの OIDC ID Token へ A3 を格納する．

Client は標準 Web ブラウザ上で動作し，W3C WebAuthn API を用いて Credential の登録および認証，RoI に伴う新 Credential の登録，WPoP 鍵ペアの生成，A3 の保存，および SP への提示を行う．認証器には Touch ID または Windows Hello などのハードウェアに裏付けられた内蔵認証器を利用できる．ブラウザ拡張，専用 Wallet アプリケーション，および Authenticator ファームウェアの変更は必要としない．

RP/IdP は，標準 WebAuthn による登録・認証に加え，認証済み Credential の退役，新 Credential の登録，1 回限りの A3 Ticket の生成，および A3 の発行を実行する．SP は，受信した A3 について，フェデレーションアサーションの署名，内部の WebAuthn Authentication Evidence，および Presentation 時の WPoP 署名を順に検証する．また，同一 A3 の再提示を拒否する accept-once 処理を実装した．

試作システムはローカルループバック上の `https://localhost:8443` で動作し，SAML および OIDC の両プロファイルについて，WebAuthn Credential の登録，パスワードレス認証，RoI による A3 生成，および SP 側の独立検証までの一連の処理を実行できる．

評価には，macOS 14.6.1 を搭載した MacBook Pro (Apple M3 チップ，24GB メモリ）を使用し，ブラウザには Chrome 149.0.7827.201 を，Authenticator には内蔵認証器 Touch ID を使用した．

5.2 評価方法

評価では，次の二つの観点を検証する．

RQ1: 実現可能性 FIDO-A3 を，既存の WebAuthn 認証器，標準 Web ブラウザ，および OIDC/SAML 基盤上で，利用者端末への追加ソフトウェアなしに実装できるか．

RQ2: 追加コスト RoI，A3 発行，Presentation，および SP による独立検証が，既存の WebAuthn およびフェデレーション処理へどの程度の計算時間および通信量を追加するか．

各処理は事前にウォームアップを行った後，同一条件で 50 回実行し，平均値および標準偏差を算出した．

Client，RP/IdP，および SP は同一のローカル実験環境上で動作させた．これは実運用環境における end-to-end latency を評価するためではなく，FIDO-A3 固有の暗号処理およびプロトコル処理によって追加される計算コストを，ネットワーク遅延や利用者操作時間から分離して測定するためである．

したがって，本評価で得られる処理時間は，FIDO-A3 による増分オーバーヘッドを示すものであり，実際の end-to-end latency には，ネットワーク往復時間，配備環境，Authenticator の種類，および利用者操作時間が別途加わる．

表 1 A3 発行処理の実行時間（平均 ± 標準偏差，$N = 50$）．Client 側 WebAuthn Credential 生成，RoI に関連する主要処理，およびサーバ側 A3 発行処理の実行時間を，SAML および OIDC プロファイルについて示す．

Table 1 Execution time of the A3 issuance process (mean ± standard deviation, N=50). The table reports the execution times of client-side WebAuthn credential generation, key operations involved in RoI, and server-side A3 issuance for the SAML and OIDC federation profiles.

処理	SAML (XML)	OIDC (JSON)
Client 側 WebAuthn Credential 生成	3638.87 ± 13.41 ms	3653.07 ± 16.34 ms
A3 Challenge 生成	4.66 ± 1.85 ms	4.74 ± 2.09 ms
A3 入力検証	8.31 ± 2.59 ms	8.12 ± 2.94 ms
Atomic Key Rotation	2.91 ± 1.09 ms	2.76 ± 1.23 ms
A3 トークン生成	14.97 ± 3.59 ms	12.19 ± 0.56 ms

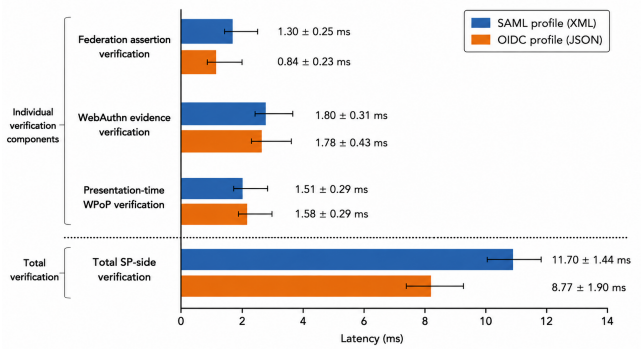


図 3 SP による独立検証の処理時間内訳．SAML および OIDC の各プロファイルについて，フェデレーションアサーション，WebAuthn 認証証跡，提示時 WPoP の検証時間，ならびに SP 側の総検証時間を示す．エラーバーは標準偏差を表す．

Fig. 3 Breakdown of SP-side independent verification latency. The figure reports the verification times for the federation assertion, WebAuthn authentication evidence, and presentation-time WPoP, together with the total SP-side verification latency for the SAML and OIDC profiles. Error bars indicate standard deviations.

本評価では，WebAuthn および OIDC/SAML の既存処理時間そのものではなく，FIDO-A3 の導入によって追加される処理のみを評価対象とする．

5.3 処理時間

表 1 に A3 発行時の主要処理時間を，図 3 に SP による独立検証の処理時間内訳を示す．本評価では，通常の WebAuthn 登録および認証に加え，RoI，A3 発行，Presentation，および SP による独立検証を対象とした．

RoI では，新 Credential の登録と旧 Credential の退役を行うとともに，一回限り利用可能な A3 Ticket を生成する．これらは既存の WebAuthn ceremony 内で実施されるため，利用者に追加のアプリケーション操作を要求しない．表 1 に示すように，Atomic Key Rotation の処理時間は SAML で 2.91 ± 1.09 ms，OIDC で 2.76 ± 1.23 ms であ

© 2026 Information Processing Society of Japan

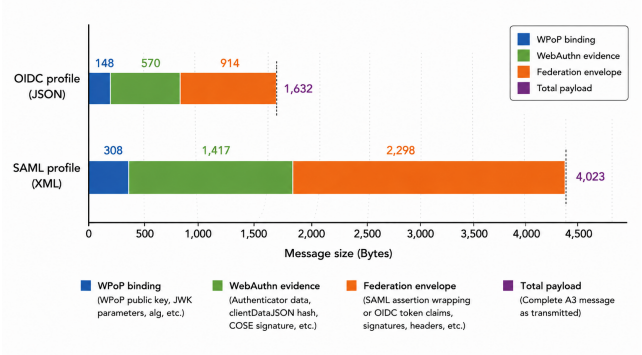


図 4 FIDO-A3 メッセージサイズの内訳．SAML および OIDC プロファイルについて，Authentication Evidence を RP 外へ運搬するために A3 へ追加される各構成要素（WPoP Binding, WebAuthn Authentication Evidence，Federation Envelope）と総ペイロードサイズを示す．

Fig. 4 Breakdown of the FIDO-A3 message size. The figure shows the components added to the A3 message to transport WebAuthn authentication evidence beyond the original RP.

り，RoI 自体の追加処理は数 ms 程度で完了する．

A3 発行では，A3 Ticket の検証，WPoP 公開鍵との結合，およびフェデレーションアサーションへの署名を行う．サーバ側の A3 発行時間は SAML で 14.97 ± 3.59 ms，OIDC で 12.19 ± 0.56 ms であり，既存のフェデレーション処理へ追加される計算コストは限定的である．

図 3 に示すように，SP 側ではフェデレーションアサーション，WebAuthn Authentication Evidence，および WPoP Binding を順に検証する．総独立検証時間は SAML で 11.70 ± 1.44 ms，OIDC で 8.77 ± 1.90 ms であり，Authentication Evidence を RP 外へ運搬して独立検証を実現するための追加処理は十数 ms 以内で完了することを確認した．このため，SP はオンラインで IdP へ再照会することなく，ハードウェアに裏付けられた Authentication Evidence を独立に検証できる．

Client 側の WebAuthn Credential 生成時間には，ブラウザおよび OS による WebAuthn ceremony，Touch ID による生体照合，Secure Enclave 内での Credential 生成が含まれる．測定時には利用者の指を Touch ID センサ上にあらかじめ置き，別の手で処理開始ボタンを押下することで，プロンプト表示後の利用者反応時間を最小化した．

本評価結果は，第 2 章で示した既存環境への適用容易性（G4）を支持するものである．

5.4 メッセージサイズ

図 4 に，FIDO-A3 メッセージのサイズ内訳を示す．FIDO-A3 では，WebAuthn Authentication Evidence に加え，WPoP Binding，Federation Envelope，および関連する署名・コンテキスト情報を A3 へ格納するため，通常のフェデレーションアサーションと比較してペイロードが増加する．

図 4 に示すように，OIDC プロファイルでは総ペイロードサイズは 1,632 Bytes，SAML プロファイルでは 4,023 Bytes であった．SAML は XML ベースのエンコーディングにより，Federation Envelope の占める割合が大きい一方，OIDC は JSON ベースであるため，総メッセージサイズを比較的小さく抑えられることが分かる．

一方，追加されるデータは一回の認証・提示セッションに対する Authentication Evidence および WPoP Binding であり，利用者端末に多数の Credential を保持することを前提とする方式ではない．また，A3 は一回限りかつ短期間の利用を想定しているため，長期 Credential を管理する Verifiable Credential 方式とはストレージ特性が異なる．

以上より，FIDO-A3 は Authentication Evidence の RP 外運搬を実現するために追加のメッセージサイズを必要とするものの，そのオーバーヘッドは既存の HTTP ベースのフェデレーション処理において実用的な範囲であることを確認した．

5.5 評価結果のまとめ

試作実装により，FIDO-A3 が既存の WebAuthn 認証器，標準 Web ブラウザ，および OIDC/SAML 基盤上で動作し，利用者端末への追加ソフトウェアや Authenticator の変更を必要としないことを確認した．この結果は，第 2 章で示した既存環境への適用容易性を支持する．

また，FIDO-A3 が追加する RoI，A3 発行，Presentation，および独立検証の処理時間と通信量を測定した結果，提案アーキテクチャを実現するための追加コストは，RoI および A3 発行が数〜十数 ms，SP 側独立検証が十数 ms 以内，追加メッセージサイズが 1.6〜4.0KB 程度であり，既存の WebAuthn およびフェデレーション処理へ現実的なオーバーヘッドで適用可能であった．

6. 比較・議論

6.1 既存方式との比較

本節では，FIDO-A3 と既存のフェデレーション認証および認証証跡保護方式との違いを整理する．表 2 に主要方式との比較を示す．

本表における「独立検証」は，Verifier が元の WebAuthn Authentication Evidence を IdP へ再照会することなく独立に検証できることを意味する．DPoP（RFC 9449）[4] および Confirmation Claim（RFC 7800）[5] は，Bearer Token の送信主体を拘束する Sender-Constrained Token 方式であり，トークンの盗難やリプレイ攻撃を防止することを目的としている．一方，これらの方式では，元の WebAuthn Authentication Evidence を SP が独立に検証することは想定していない．

© 2026 Information Processing Society of Japan

表 2　Authentication Evidence の検証方式に着目した既存方式との比較
Table 2　Comparison of Existing Approaches

方式	独立検証	検証対象	同一オリジン制約維持	追加 Client	主目的
DPoP [4] / RFC7800 [5]	×	Token	○	不要	Token 拘束
VC [6] / EUDI [7]	×	Credential	–	Wallet	Credential 提示
FIDO-AC [8]	△	Credential	○	必要	匿名認証・属性提示
FIDO-A3	○	Authentication Evidence	○	不要	Authentication Evidence の独立検証

W3C Verifiable Credential [6] や EUDI Wallet [7] は，事前発行された Credential を利用者が提示することを目的としており，発行済み Credential の真正性や属性を検証することができる．しかし，WebAuthn 認証イベントそのものを RP 外へ運搬し，SP が Authentication Evidence を独立に検証することは対象としていない．

FIDO-A3 は，WebAuthn の同一オリジン制約を維持したまま，Authentication Evidence の Verification Scope を RP 外へ拡張し，SP による独立検証を実現する点で，これら既存方式とは問題設定および設計目的が異なる．

6.2　制約と残存する信頼

FIDO-A3 は，Authentication Evidence について SP による独立検証を可能とする一方，フェデレーション認証におけるすべての信頼を除去するものではない．

利用者属性，アカウント状態，認証時刻，およびフェデレーション上の意味付けについては，引き続き IdP を信頼する必要がある．また，IdP が RoI を正しく実行し，退役した Credential を以後の認証に利用しないことも前提となる．

FIDO-A3 は，Authentication Evidence を一回限り利用可能な A3 として運搬する方式であり，長期利用を前提とする Credential とは運用モデルが異なる．したがって，Verifiable Credential における失効リストや長期 Credential 管理とは異なる設計思想を採用している．

6.3　今後の展望

FIDO-A3 は，WebAuthn Authentication Evidence の Verification Scope を RP 外へ拡張するフェデレーションアーキテクチャである．

Authentication Evidence を既存の Trust Boundary の外部へ安全に運搬し，受信側が独立に検証可能とする考え方は，Wallet を利用した Credential 提示や，AI Agents への権限委譲など，複数の Trust Boundary をまたぐ将来のアイデンティティアーキテクチャへも適用可能と考えられる．

今後は，Wallet 環境や AI Agents 環境を対象とした Authentication Evidence および権限委譲に関する証跡の安全な運搬方式について検討を進める予定である．

FIDO-A3 は，WebAuthn Authentication Evidence の Verification Scope を RP 外へ拡張するための基盤アーキテクチャとして位置付けられる．

7.　おわりに

本稿では，WebAuthn の同一オリジン制約を維持したまま，RP 外の SP が Authentication Evidence を独立に検証可能とするフェデレーションアーキテクチャ FIDO-A3 を提案した．

FIDO-A3 は，RoI によって継続的な WebAuthn 認証とサービス間非リンク性を維持しつつ，Authentication Evidence の Verification Scope を RP 外へ拡張する．さらに，既存の WebAuthn 認証器，標準 Web ブラウザ，および OIDC/SAML 基盤上で追加ソフトウェアを必要とせず実装可能であること，ならびに，追加される処理時間および通信量が実用的な範囲であることを示した．

Authentication Evidence を既存の Trust Boundary の外部へ安全に運搬し，受信側が独立に検証可能とする考え方は，アイデンティティフェデレーションにとどまらず，Wallet，AI Agents，および今後の分散アイデンティティ基盤においても重要な設計原則になると考えられる．

今後は，Trust Boundary を越えて Authentication Evidence および権限委譲に関する証跡を安全に運搬・検証するためのアイデンティティアーキテクチャについて研究を進める予定である．

参考文献

[1] W3C: Web Authentication: An API for Accessing Public Key Credentials – Level 2 (2021).
[2] OpenID Foundation: OpenID Connect Core 1.0 (2023).
[3] OASIS: Assertions and Protocols for the OASIS Security Assertion Markup Language (SAML) V2.0 (2015).
[4] Fett, D., Nystrom, B., Bradley, J., Lodderstedt, T., Jones, M. and Waite, D.: OAuth 2.0 Demonstrating Proof of Possession (DPoP), RFC 9449 (2023).
[5] Jones, M., Bradley, J. and Tschofenig, H.: Proof-of-Possession Key Semantics for JSON Web Tokens (JWTs), RFC 7800 (2016).
[6] W3C: Verifiable Credential Data Model v2.0, W3C Candidate Recommendation Draft (2024).
[7] European Commission: The European Digital Identity Wallet Architecture and Reference Framework (ARF) (2026). Version 2.8.0.
[8] Yeoh, W.-Z., Kepkowski, M., Heide, G., Kaafar, D. and Hanzlik, L.: Fast IDentity Online with Anonymous Credentials (FIDO-AC), *Proc. USENIX Security*, pp. 3029–3046 (2023).

© 2026 Information Processing Society of Japan

付　　録

A.1　RoI アルゴリズム

本節では，RoI の基本的な状態遷移をアルゴリズムとして示す（Algorithm 1）．

本アルゴリズムでは，cid は WebAuthn Credential Identifier（ID），pk は対応する検証用公開鍵，θ は Authentication Evidence を表す．添字 old および new は，それぞれ退役する Credential と，新たに登録される Credential を示す．

Algorithm 1 Rotation-on-Issuance

Require: Authenticated context $(cid_{\text{old}}, pk_{\text{old}}, \theta)$
1: Generate a fresh issuance challenge c_{A3}
2: Perform WebAuthn registration with c_{A3}
3: Verify the resulting registration evidence
4: Obtain a fresh credential $(cid_{\text{new}}, pk_{\text{new}})$
5: Construct an A3 ticket referring to $(pk_{\text{old}}, \theta)$
6: Atomically discontinue cid_{old} and register $(cid_{\text{new}}, pk_{\text{new}})$
7: **return** A3 ticket

A.2　FIDO-A3 論理データ構造

本節では，A3 に格納される主要な論理構成要素を示す（図 A·1）．Authentication Evidence および WPoP Binding は，Federation Envelope へ格納され，一つの署名対象として保護される．

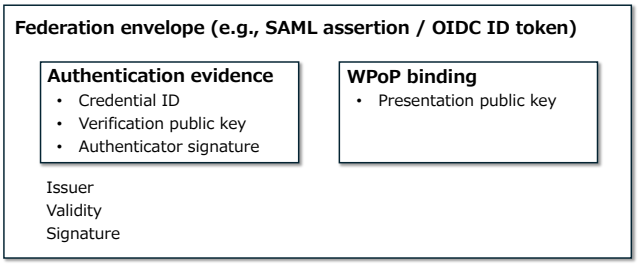


図 A·1　FIDO-A3 論理データ構造．
Fig. A·1　FIDO-A3 data structure.

A.3　Protocol Notes

本節では，本文 Figure 2 の各フェーズについて，主要な処理内容を補足する．

(1) **Registration:** RP は標準 WebAuthn による Credential 登録を実施し，Registration Evidence を検証する．本フェーズは既存の WebAuthn 登録処理を変更しない．

(2) **Authentication:** RP は標準 WebAuthn 認証を実施し，Authentication Evidence を取得する．この Authentication Evidence が，後続の A3 発行における暗号学的証跡となる．

(3) **Rotation-on-Issuance（RoI):** RP は新しい WebAuthn Credential を登録すると同時に，認証に使用した Credential を退役させる．退役した Credential は，以後の WebAuthn 認証には使用されず，当該 A3 に含まれる Authentication Evidence を検証するための一回限りの Verification Anchor となる．また，発行コンテキストに対応する一回限りの A3 Ticket を生成する．

(4) **A3 Issuance:** Client は Presentation に用いる WPoP 鍵対を生成する．RP は，
- Authentication Evidence
- 検証用公開鍵
- WPoP 公開鍵
- 発行コンテキスト

を A3 へ結合し，Federation Envelope として署名する．この署名により，Authentication Evidence と Presentation 公開鍵との対応関係が保護される．

(5) **Presentation:** Client は A3 と WPoP を SP へ提示する．SP は
- Federation 署名
- Authentication Evidence
- WPoP Binding

を検証し，元の RP へ再照会することなく，ハードウェアに裏付けられた Authentication Evidence を独立に検証する．

© 2026 Information Processing Society of Japan